

Cybersecurity Capstone Project — Choose Your Track

20 Project Options — GRC · Penetration Testing · SOC (Attack & Defend) — Teams of 6

Team Size	6 students per team	Categories	GRC (7) · Pentesting (7) · SOC (6)
Deliverables	Written report + presentation + evidence (screenshots, logs, diagrams)		

Before You Start — Rules for Everyone

1. Pick your team of 6 and assign every role listed under your chosen project — nobody sits out, and each of you will be graded individually on your role.
2. All hacking, scanning, and attack/defense work happens **only** inside the lab environment your instructor gives you. Never point any tool at a real, external target.
3. Keep evidence as you go — screenshots, logs, notes. If you don't document it, it didn't happen.
4. Your final report must include: what you did, how you did it, what you found, and what you'd recommend to fix it.
5. You'll present a 10-15 minute demo of your work to the class — be ready to explain your decisions, not just show a slide.
6. Copying a report from a previous class or from the internet = automatic disqualification.

Track 1 — GRC (Governance, Risk & Compliance)

You'll be given a fictional company. Your job is to think like a security manager, not a hacker: find the risks, map them to real frameworks, and tell the company what to fix first.

1. MedCore Clinics — Protecting Patient Data

Your scenario: MedCore is a chain of clinics moving all patient records to a cloud-based system, with no security policy in place yet.
What you'll do: Build a risk register for patient data, identify the realistic threats (insider misuse, ransomware, a careless cloud vendor), map your findings to a recognized framework (ISO 27001 or NIST CSF), and hand the clinic a prioritized list of what to fix first.

- Risk Analyst
- Compliance Officer
- Threat Modeler
- Control Owner / Auditor
- Policy Writer
- Team Lead / Presenter

You must name a real framework you're using and build a scored risk matrix (likelihood × impact) covering at least 12 risks.

2. NileTrade — Getting Fintech Investment-Ready

Your scenario: NileTrade is a payments startup that needs to prove to investors it takes security seriously before it gets funded.
What you'll do: Run a gap analysis against PCI-DSS, draw a data-flow diagram of how card data moves through the company, identify the biggest threats along that flow, and write a board-level risk report.

- PCI-DSS Gap Analyst
- Data-Flow Architect
- Threat Analyst
- Policy Author
- Third-Party Risk Reviewer
- Team Lead / Presenter

Your data-flow diagram must be a real diagram, not a description. Classify at least 3 vendors by risk level.

3. Atlas Manufacturing — Securing a Smart Factory

Your scenario: Atlas just connected its old factory equipment (ICS/SCADA) to the corporate network so managers can monitor it remotely.

What you'll do: Analyze the risk of mixing IT and factory-floor (OT) networks, identify threats unique to industrial equipment (old protocols, unpatched control panels), and design a governance plan that both IT and factory managers can follow.

- OT Risk Analyst
- IT/OT Segmentation Reviewer
- Threat Modeler
- Business Impact Analyst
- Governance/Policy Lead
- Presenter

Include a Business Impact Analysis estimating what downtime would cost the factory. Propose a network segmentation plan.

4. EduCloud — A University Moves to the Cloud

Your scenario: A university wants to move student records and research data to a public cloud, and leadership needs a clear yes-or-no recommendation.

What you'll do: Assess the risk of the migration, review who is responsible for what between the university and the cloud provider, evaluate the provider itself, and deliver a formal go/no-go recommendation.

- Cloud Risk Analyst
- Vendor Assessor
- Identity & Access Reviewer
- Compliance Checklist Owner
- Threat Analyst
- Presenter / Lead

You must clearly state what the cloud provider secures versus what the university still has to secure, and justify your final recommendation.

5. PortLogix — Managing Third-Party Risk at a Seaport

Your scenario: PortLogix relies on dozens of outside vendors and contractors with remote access into its systems.

What you'll do: Build a vendor risk-management program: inventory the vendors, review their access levels, think through supply-chain attack scenarios, and write a policy for what happens if a vendor gets breached.

- Supply-Chain Risk Analyst
- Vendor Access Reviewer
- Threat Modeler
- Business Continuity Planner
- Policy Writer
- Presenter

Build a vendor risk-tiering table (Critical/High/Medium/Low) with your reasoning, and reference one real-world supply-chain breach as a case study.

6. SkyRoute Airlines — Third-Party App and Airport Systems Risk

Your scenario: SkyRoute just launched a new booking app built by an outside contractor and integrated it with internal airport check-in systems.

What you'll do: Assess the risk introduced by the new app and its contractor, evaluate the integration points with internal systems, and produce a risk acceptance report with sign-off recommendations for management.

- Application Risk Analyst
- Integration Risk Reviewer
- Threat Modeler
- Contractor/Vendor Assessor
- Policy Writer
- Presenter

You must identify at least 3 integration points between the app and internal systems and rate the risk of each individually.

7. GreenGrid Utility — Risk Assessment for Power Infrastructure

Your scenario: GreenGrid manages regional power distribution and is under pressure to prove resilience against cyberattacks after a similar utility was hit elsewhere.

What you'll do: Perform a critical infrastructure risk assessment, identify threats to availability (the utility's top priority), and design an incident-notification and regulatory-reporting policy.

- Critical Infrastructure Risk Analyst
- Availability/Resilience Reviewer
- Threat Modeler
- Regulatory/Reporting Policy Writer
- Business Continuity Planner
- Presenter

Your risk assessment must rank availability threats as the top priority and justify why, given the utility's role.

Track 2 — Penetration Testing

You'll be given a vulnerable target environment. Your job is to find real, exploitable vulnerabilities — not just run a scanner — and prove impact.

8. Web App Pentest — "ShopEase"

Your target: A deliberately vulnerable e-commerce web app provided in your lab.

What you'll do: Test the app against the OWASP Top 10 (SQL injection, XSS, broken authentication, IDOR, etc.), chain vulnerabilities together to reach admin access or sensitive data, and write a professional report with CVSS scores for every finding.

- Recon Lead
- Web App Exploiter (Auth/Session)
- Web App Exploiter (Injection)
- Privilege Escalation Specialist
- Evidence/Documentation Lead
- Report Writer / Presenter

You need at least 5 distinct vulnerability types, each manually verified and exploited — scanner output alone doesn't count.

9. Internal Network Pentest — "Corplab"

Your target: A simulated corporate network with a domain controller, file server, and workstations.

What you'll do: Start from a single compromised workstation. Enumerate the network, harvest credentials, move laterally, and escalate all the way to Domain Admin.

- Network Enumeration Lead
- Credential Harvester
- Lateral Movement Specialist
- Privilege Escalation Specialist
- Persistence/Cleanup Lead
- Report Writer / Presenter

Submit an attack-path diagram from your starting foothold to Domain Admin, and demonstrate at least one credential-based attack (pass-the-hash, Kerberoasting, etc.) with evidence.

10. Wireless & IoT Pentest — "SmartHomeLab"

Your target: A small office lab with Wi-Fi and several IoT devices (cameras, smart plugs, a router) left on weak or default settings.

What you'll do: Attack the wireless network, find and exploit weaknesses in the IoT devices (default credentials, exposed services), and try to pivot from a compromised device into the wider network.

- Wireless Attack Lead
- IoT Device Analyst
- Rogue AP / MITM Specialist
- Pivoting Specialist
- Evidence Collector
- Report Writer / Presenter

Document at least one successful wireless attack and one IoT compromise. Any pivot into the network must be diagrammed and backed by screenshots.

11. Social Engineering & Phishing Assessment — "HR Test"

Your target: A mock company's staff, played by another team or provided by your instructor.

What you'll do: Design and run a phishing simulation with tracking, build a believable pretext for a social engineering scenario, and analyze why it worked (or didn't) — then recommend fixes.

- Phishing Campaign Designer
- Pretext/Scenario Writer
- Infrastructure Setup (tracking/landing page)
- Metrics & Analytics Lead
- Awareness Recommendations Lead
- Report Writer / Presenter

Get written sign-off from your instructor before running anything — no real external targets, ever. Report your actual click-rate and credential-submission numbers, not estimates.

12. API & Mobile Backend Pentest — "RideNow"

Your target: A mock ride-hailing app's backend (REST/GraphQL API) with weak access controls and authentication.

What you'll do: Map every API endpoint, then test for broken object-level authorization, excessive data exposure, weak tokens/JWTs, and privilege escalation between rider, driver, and admin roles.

- API Recon/Mapping Lead
- Auth/Token Exploiter
- BOLA/Access Control Specialist
- Fuzzing/Input Testing Lead
- Evidence Documenter
- Report Writer / Presenter

Map the full API before you start attacking — no blind fuzzing as your only method. Demonstrate one full privilege escalation from a low-level account to an admin action.

13. Cloud Environment Pentest — "CloudNest"

Your target: A lab cloud environment (e.g., AWS/Azure sandbox) with misconfigured storage buckets, over-permissive IAM roles, and exposed credentials.

What you'll do: Enumerate cloud resources, find misconfigurations (public buckets, weak IAM policies), escalate privileges within the cloud account, and demonstrate what an attacker could access or steal.

- Cloud Recon Lead
- IAM/Privilege Escalation Specialist
- Storage/Data Exposure Specialist
- Credential Hunter
- Evidence Documenter
- Report Writer / Presenter

Only touch resources inside the lab cloud account you're given. Document the full privilege escalation path with proof of what you could ultimately access.

14. Physical & Badge Security Assessment — "OfficeBreach"

Your target: A simulated office environment (can be tabletop/staged) with badge access, unlocked workstations, and unattended documents.

What you'll do: Assess physical security controls, attempt simulated tailgating/badge-cloning scenarios (as approved by your instructor), and identify how easily an attacker could gain a foothold through physical access.

- Physical Recon Lead
- Badge/Access Control Analyst
- Social Engineering Support
- Evidence Collector
- Risk-to-Digital Impact Analyst
- Report Writer / Presenter

Nothing in this project happens on a real, non-sanctioned site — get instructor approval for the exact scenario first. Tie every physical weakness you find to a digital-security consequence.

Track 3 — SOC / Attack & Defend (Red vs. Blue)

Your team of 6 splits into 3 attackers (Red) and 3 defenders (Blue). Red attacks a target environment while Blue watches, detects, and responds —

15. Live Ransomware Simulation — "CryptoWatch"

The exercise: Red tries to deploy a simulated (harmless) ransomware payload across a small lab network. Blue has to catch it via SIEM/EDR alerts before it fully "encrypts" everything.

Red's job: Get initial access, move laterally, trigger the payload. **Blue's job:** Monitor logs and alerts, detect the intrusion, contain the affected hosts, and write up a full incident timeline.

- **Red:** Initial Access Operator, Lateral Movement Operator, Payload/Execution Operator
- **Blue:** SOC Analyst/Detection Lead, Incident Responder/Containment Lead, Log & Timeline Analyst

Blue doesn't get told Red's attack path in advance. Blue's report must show a full timeline comparing when the attack started versus when it was detected. Red logs every action taken for the after-action review.

16. Web Server Compromise & Detection — "PublicPortal"

The exercise: Red targets a public-facing web server running a vulnerable CMS to get a foothold and stay persistent. Blue watches web and network logs for signs of trouble.

Red's job: Exploit the app, get a reverse shell, set up persistence. **Blue's job:** Catch the exploitation attempt, find the persistence mechanism, remove it, and document indicators of compromise.

- **Red:** Exploitation Lead, Shell/C2 Operator, Persistence Specialist
- **Blue:** Network Traffic Analyst, Host/Log Analyst, Incident Responder & IOC Writer

Blue must produce a usable list of indicators of compromise (IPs, file hashes, persistence artifacts). Red has a fixed time window (e.g., 90 minutes) to get in and stay in.

17. Insider Threat & Data Exfiltration — "LeakWatch"

The exercise: Red plays a malicious insider with valid low-level credentials trying to quietly steal sensitive data. Blue has to notice the unusual data movement.

Red's job: Escalate privileges quietly and exfiltrate a marked file set without setting off obvious alarms. **Blue's job:** Baseline normal activity, catch the anomaly, and respond with account lockdown and a report.

- **Red:** Privilege Escalation Operator, Exfiltration Channel Specialist, Anti-Detection/Evasion Operator
- **Blue:** Baseline/Anomaly Analyst, DLP/Network Monitor, Incident Responder & Reporting Lead

Red must actually exfiltrate the specific "flag" file your instructor gives you to prove success. Blue must name the exact alert or log entry that led to detection — no vague claims.

18. Active Directory Attack & Defense — "DomainSiege"

The exercise: Red attacks a small Active Directory environment using common techniques (Kerberoasting, password spraying, ACL abuse). Blue watches AD/Windows event logs and tries to stop Red before Domain Admin is reached.

Red's job: Start with a low-privilege account and escalate to Domain Admin. **Blue's job:** Catch the suspicious authentication/escalation activity, respond, and harden the environment while the exercise is running.

- **Red:** Password Spray/Initial Access Operator, Kerberoasting/AD Enumeration Operator, Escalation/Domain Admin Operator
- **Blue:** AD/Event Log Analyst, SOC Alert Triage Lead, Hardening & Response Lead

Blue can apply live fixes mid-exercise (disable an account, reset a password) but must log each action with a timestamp and reason. The round ends when Red reaches Domain Admin or Blue fully contains the attack — whichever happens first.

19. DDoS & Availability Attack/Defense — "UptimeGuard"

The exercise: Red launches a controlled, lab-only denial-of-service style attack against a target service. Blue has to keep the service up.

Red's job: Degrade or take down the target using traffic-based or application-layer attack techniques. **Blue's job:** Monitor availability and traffic, spot the attack pattern, and mitigate it in real time (rate limiting, filtering, failover).

- **Red:** Traffic Generation Lead, Application-Layer Attack Specialist, Attack Timing/Coordination Lead
- **Blue:** Traffic/Availability Monitor, Mitigation Engineer, Incident Reporting Lead

All traffic stays strictly inside your isolated lab range — never aimed at anything real or external. Blue is graded on the uptime percentage they manage to hold during the attack window.

20. Phishing-to-Breach Full Chain — "InboxZero"

The exercise: Red sends a simulated phishing email to a "victim" workstation in the lab to gain initial access, then tries to pivot deeper into the network. Blue monitors email gateway logs, endpoint alerts, and network traffic to catch the chain as early as possible.

Red's job: Get a click, establish a foothold, and attempt at least one lateral move. **Blue's job:** Detect the phishing attempt (or its payload), isolate the affected host, and trace how far Red got before containment.

- **Red:** Phishing/Delivery Operator, Foothold/Payload Operator, Lateral Movement Operator
- **Blue:** Email/Gateway Analyst, Endpoint Detection Analyst, Incident Responder & Timeline Writer

The phishing email only ever goes to the lab "victim" account — never to a real inbox. Blue's final report must state exactly where in the chain the attack was stopped (email, endpoint, or network stage).